

Tugas Menjawab Pertanyaan II

Enkripsi, Hashing, ADS, dan Keamanan Password

Bagian 1

Pertanyaan dan jawaban

1. Kenapa hash cocok untuk verifikasi integritas?

Karena data berubah satu bit aja, hashnya akan sangat berubah (ini disebut sebagai *avalanche effect*). Hash ini penting untuk verifikasi integritas data karena berfungsi sebagai “sidik jari digital” dari suatu data. Dengan menggunakan fungsi hash seperti SHA-256 atau MD5 (yang saya terapkan SHA-256), data apapun akan diubah menjadi nilai unik dengan panjang tetap. Keunggulan utamanya adalah sifat sensitif terhadap perubahan sekecil apapun (misal seperti yang saya sebutkan diawal satu bit data berubah, maka nilai hash yang dihasilkan akan berbeda secara signifikan). Karena hal tersebut memungkinkan untuk mendeteksi apakah suatu data tetap utuh atau sudah mengalami perubahan.

2. Dalam skenario kerja, kapan verifikasi *hash* wajib dilakukan?

Verifikasi hash menjadi wajib dilakukan ketika ada risiko perubahan data, manipulasi, atau ketika integritas data harus bisa dibuktikan. Salah satu skenario utamanya adalah saat menerima file dari luar sistem seperti *attachment* email, hasil *download*, atau file dari pihak ketiga. Disini, hash (misalnya dengan SHA-256) digunakan untuk memastikan file tidak disusupi malware atau berubah selama proses transfer, tanpa verifikasi file yang terlihat normal bisa jadi sudah dimodifikasi secara berbahaya.

Bagian 2

Pertanyaan dan jawaban

1. Mengapa ADS sering disalahgunakan malware?

ADS pada NTFS sering disalahgunakan karena memungkinkan penyimpanan data tersembunyi tanpa terlihat oleh pengguna biasa maupun tool sederhana. Malware memanfaatkan ADS untuk menyimpan payload, script, atau konfigurasi berbahaya di dalam file yang tampak normal (misalnya laporan.txt). Karena Windows

Explorer dan banyak proses inspeksi dasar tidak menampilkan stream tambahan, attacker bisa menyembunyikan aktivitasnya dengan lebih mudah. Selain itu, ADS tidak mengubah tampilan file utama secara signifikan, sehingga teknik ini efektif untuk *stealth* dan *persistence*. Pada beberapa kasus, malware bahkan dijalankan langsung dari ADS atau dipanggil oleh script tertentu, sehingga keberadaannya makin sulit dideteksi.

2. Apa risiko jika proses inspeksi file hanya melihat “nama *file* utama”

Jika inspeksi hanya berfokus pada file utama (*main stream*), maka semua data tersembunyi di ADS akan terlewat. Ini berisiko tinggi karena file yang terlihat aman sebenarnya bisa menyimpan malware, *credential*, atau data sensitif di dalam *stream* tersembunyi. Akibatnya, sistem keamanan bisa salah menganggap file tersebut tidak berbahaya (*false negative*). Dalam konteks incident response atau digital forensics, hal ini juga dapat menyebabkan analisis tidak lengkap karena sebagian bukti tersembunyi tidak terdeteksi. Oleh karena itu, inspeksi yang aman harus mencakup seluruh *stream* dalam file, bukan hanya nama atau isi utama saja.

Bagian 3

Pertanyaan dan jawaban

1. Mengapa */etc/shadow* harus hanya bisa diakses root?

Karena file */etc/shadow* menyimpan informasi autentikasi paling sensitif di sistem Linux, yaitu hash password dari semua user. Jika file ini bisa diakses oleh user biasa, maka keamanan seluruh file bisa terancam. Meskipun dalam bentuk hash bukan plaintext, hash tetap bisa diserang menggunakan teknik seperti *brute force* atau *dictionary attack*. Jika attacker mendapatkan isi file ini, mereka bisa mencoba memecahkan password secara offline tanpa batasan, yang mana itu jauh lebih berbahaya dibandingkan serangan login biasa. Dengan membatasi akses hanya ke root, sistem menerapkan prinsip *least privilege*, yaitu hanya pihak yang benar-benar membutuhkan yang bisa mengakses data sensitif. Selain itu juga semisal */etc/shadow* bisa dimodifikasi oleh sembarang user, attacker dapat langsung mengganti hash password dan mengambil alih akun lain, termasuk akun root.

2. Apa perbedaan peran */etc/passwd* vs */etc/shadow*?

/etc/passwd menyimpan informasi dasar user seperti username, UID, home directory, dan shell, serta bisa dibaca oleh semua user karena tidak berisi data

sensitif. Sementara itu, `/etc/shadow` menyimpan hash password dan informasi keamanan terkait, biasanya menggunakan algoritma seperti SHA-512, dan hanya bisa diakses oleh root. Intinya, `/etc/passwd` berisi identitas user (publik), sedangkan `/etc/shadow` berisi autentikasi (rahasia).

Bagian 4

Pertanyaan dan jawaban

1. Mengapa salt mencegah penggunaan ulang tabel hash (rainbow/precompute)?

Salt mencegah penggunaan ulang tabel hash (rainbow/precompute) karena membuat setiap proses hashing menjadi unik untuk setiap user atau setiap instance password. Pada sistem tanpa salt, satu password selalu menghasilkan hash yang sama (misalnya dengan MD5), sehingga attacker bisa membuat tabel hash sekali lalu menggunakannya berulang kali untuk banyak target.

Namun ketika salt ditambahkan, password tidak lagi di-hash secara langsung, melainkan dikombinasikan dengan nilai acak (salt) sebelum di-hash. Akibatnya, password yang sama akan menghasilkan hash yang berbeda jika salt-nya berbeda. Karena setiap user memiliki salt yang unik, maka tabel hash yang dibuat sebelumnya tidak bisa digunakan kembali. Attacker harus membuat tabel baru untuk setiap kombinasi salt, yang secara praktis sangat tidak efisien dan memakan sumber daya besar. Hal tersebut yang membuat salt efektif dalam mencegah serangan berbasis precomputation seperti rainbow table.

2. Jika dua pengguna memakai password yang sama, apa yang terjadi pada hash salted?

Hash yang dihasilkan tetap berbeda. Hal ini karena setiap user memiliki nilai salt yang unik, sehingga proses hashing menjadi berbeda meskipun input passwordnya sama.

Secara konsep:

User A : password + salt A = hash A

User B : password + salt B = hash B

Walaupun password User A dan User B identik, hasil akhirnya (digest) tidak akan sama karena dipengaruhi oleh salt yang berbeda. Ini berbeda dengan sistem legacy tanpa salt, di mana password yang sama akan menghasilkan hash yang sama.

Bagian 5

Pertanyaan dan jawaban

1. Jelaskan perbedaan “lebih lambat karena algoritma” vs “lebih mahal karena salt tidak bisa digunakan ulang”.

“Lebih lambat karena algoritma” berarti setiap proses hashing memang sengaja dibuat berat oleh desain algoritma modern seperti bcrypt atau Argon2. Algoritma ini menggunakan teknik seperti key stretching (pengulangan proses hashing) dan penggunaan memori besar, sehingga satu kali percobaan password saja membutuhkan waktu lebih lama. Akibatnya, attacker tidak bisa mencoba banyak password dalam waktu singkat karena setiap percobaan “mahal” secara komputasi.

Sementara itu, “lebih mahal karena salt tidak bisa digunakan ulang” bukan tentang lambatnya satu proses hashing, tetapi tentang tidak bisa reuse hasil kerja sebelumnya. Tanpa salt, attacker bisa membuat tabel hash (precompute/rainbow table) sekali lalu menggunakannya untuk banyak user atau sistem. Dengan adanya salt, setiap user memiliki nilai berbeda, sehingga attacker harus menghitung ulang hash untuk setiap kombinasi password dan setiap user. Ini membuat total pekerjaan menjadi jauh lebih banyak, walaupun tiap hashing tidak selalu lebih lambat.

2. Kebijakan apa saja yang memperkecil peluang password berhasil ditebak?

Kebijakan yang dapat memperkecil peluang password berhasil ditebak berfokus pada membuat password lebih sulit ditebak dan membatasi percobaan attacker. Dengan menggunakan algoritma hashing modern seperti Argon2 atau bcrypt yang sudah dilengkapi salt dan cost factor, sehingga setiap percobaan password menjadi mahal secara komputasi. Selain itu, terapkan kebijakan password yang kuat, seperti panjang minimal (misalnya minimal 12 karakter), kombinasi huruf besar, kecil, angka, dan simbol, serta melarang penggunaan password umum atau yang mudah ditebak. Serta, penting untuk menerapkan mekanisme pembatasan percobaan login

seperti rate limiting atau account lockout agar serangan brute force online tidak bisa dilakukan secara bebas. Penggunaan multi-factor authentication (MFA) juga sangat efektif karena menambahkan lapisan keamanan tambahan meskipun password berhasil ditebak. Di sisi lain, edukasi pengguna agar tidak menggunakan password yang sama di banyak layanan (password reuse) juga penting untuk mencegah efek domino jika terjadi kebocoran data. Terakhir, monitoring dan audit login secara berkala membantu mendeteksi aktivitas mencurigakan sejak dini sehingga risiko dapat diminimalkan.